

What Is Security Testing?

What Is Security Testing?

Security testing is an important aspect of software testing focused on identifying and addressing security vulnerabilities in a software application. It aims to ensure that the software is secure from malicious attacks, unauthorized access, and data breaches.

Security testing involves verifying the software's compliance with security standards, evaluating the security features and mechanisms, and conducting penetration tests to identify weaknesses and vulnerabilities that might be exploited by malicious actors.

The goal of security testing is to identify security risks and offer recommendations for remediation to improve the overall security of the software application. Testers simulate attacks to check existing security mechanisms and look for new vulnerabilities.

This is part of a series of articles about [application security](#).

Why Is Security Testing Important?

Security testing is important for several reasons:

- **Protects sensitive data:** Security testing helps ensure that confidential and sensitive information is protected from unauthorized access, disclosure, or theft.
- **Prevents security breaches:** By identifying vulnerabilities and weaknesses in the system, security testing helps prevent security breaches and unauthorized access to sensitive data.
- **Maintains trust:** Security testing helps maintain the trust of customers, clients, and users by demonstrating that the system is secure and their information is protected.
- **Meets compliance requirements:** Many industries and organizations are subject to regulations that require specific security measures, and security testing helps ensure compliance with these regulations.
- **Improves system reliability:** Security testing can help identify and resolve security weaknesses that can cause system failures or crashes, improving overall system reliability.

In short, security testing is crucial for protecting sensitive data, maintaining trust, meeting compliance requirements, and improving system reliability.

What Are the Main Types of Security Testing?

Vulnerability Scanning

Vulnerability scanning involves automated tools to identify security vulnerabilities in a software application or network. The aim of vulnerability scanning is to identify and report potential security threats and recommend remediation measures. It provides a security baseline and focuses on known risks.

Penetration Testing

Penetration testing is a subset of ethical hacking that involves simulating real-world attacks to locate vulnerabilities in a software application. The goal of penetration testing is to identify potential security threats and how to remediate them. Penetration testing can be performed either manually or with automated tools and may include techniques such as social engineering, network scanning, and application-layer testing.

Application Security Testing

Application security testing (AST) is the process of evaluating the security of a software application and identifying potential vulnerabilities. It involves a combination of automated and manual testing techniques, such as code analysis, penetration testing, and security scanning. The goal of application security tests is to detect and mitigate security risks to the software application. AST is important for identifying both external and internal threats.

Web App Security Testing

Web application security testing is a specialized type of AST that focuses on identifying vulnerabilities in web-based applications. This type of testing typically involves a combination of manual and automated testing methods, such as SQL injection testing, cross-site scripting (XSS) testing, and authentication testing.

API Testing

API security testing involves evaluating the security of an application's APIs and the systems that they interact with. This type of testing typically involves sending various types of malicious requests to the APIs and analyzing their responses to identify potential

vulnerabilities. The goal of API security testing is to ensure that APIs are secure from attacks and that sensitive data is protected.

This is important because APIs are vulnerable to specific threats, including denial-of-service (DoS) attacks, API injection, and man-in-the middle (MitM) attacks, where an attacker intercepts the API communications to steal sensitive information.

Security Auditing

Security auditing is the process of evaluating the security of a software application or network to identify potential vulnerabilities and to ensure that it is in compliance with security standards and best practices. This type of testing typically includes manual methods, such as code review, vulnerability scanning, and penetration tests.

Risk Assessments

A risk assessment involves identifying potential security threats and assessing the possible impact of these threats on a software application or network. The goal of a risk assessment is to prioritize the security risks based on their predicted impact and to develop a plan to mitigate these risks.

Security Posture Assessments

Security posture assessments involve evaluating an organization's overall security posture, including its policies, procedures, technologies, and processes. Regular assessments can help to identify potential security risks and recommend ways of improving the overall security strategy and implementation of the organization.

Types of Security Testing Tools

SAST (Static Application Security Testing)

SAST, also known as static code analysis, is a type of security testing tool that analyzes the source code of a software application without executing it. The goal of SAST is to identify potential security vulnerabilities early in the software development lifecycle, before the application is deployed. SAST tools typically use a variety of techniques, including code review, data flow analysis, and vulnerability scanning, to identify potential security issues.

DAST (Dynamic Application Security Testing)

DAST, also known as dynamic analysis or black box testing, is a type of security testing tool that evaluates a software application while it is running. The goal of DAST is to identify potential security vulnerabilities by sending requests to the application and observing its behavior. DAST tools typically use techniques such as vulnerability scanning, penetration testing, and data flow analysis to identify security issues.

IAST (Interactive Application Security Testing)

IAST is a type of security testing tool that combines elements of SAST and DAST to provide real-time analysis of a software application while it is running. IAST tools are designed to detect security vulnerabilities and to provide immediate feedback to the application so that it can respond appropriately.

SCA (Software Composition Analysis)

Software composition analysis analyzes the third-party components that are used in a software application. The goal of SCA is to identify potential security vulnerabilities in the third-party components and to provide recommendations for remediation. SCA tools typically use a combination of automated and manual testing methods, and have helped foster a culture of shifting security to the left (i.e., implementing security earlier in the development lifecycle).

MAST (Mobile Application Security Testing)

MAST solutions are specifically designed to evaluate the security of mobile applications. The goal of MAST is to identify potential security vulnerabilities in mobile applications and to provide recommendations for remediation. MAST tools typically use techniques such as vulnerability scanning, penetration testing, and static and dynamic testing.

RASP (Runtime Application Self-Protection)

RASP is a type of security testing tool that is designed to protect a software application from security threats by providing real-time analysis of the application's behavior. RASP tools are designed to detect and respond to security threats in real-time, allowing the application to defend itself against attacks. RASP tools typically use techniques such as data flow analysis, vulnerability scanning, and penetration testing.

Security Testing with HackerOne

While application security testing tools powered by automation and AI offer some benefits, they are not a silver bullet. Automated AST will often miss deeply rooted, elusive vulnerabilities that bad actors target, have limitations in language support, and often produce a deluge of false positives that frustrate developers and security professionals alike.

The HackerOne Attack Resistance Platform removes these roadblocks by taking a preemptive approach to security, designed to outmatch cybercriminals with expertise from a legion of ethical hackers who work for you:

- HackerOne identifies a complete inventory of your digital assets.
- Ethical hackers provide context to map your assets for comprehensive visibility and control.
- They pinpoint the most critical flaws in your asset inventory and risk rank them for prioritized scoping, and continually test those assets from an adversarial point of view to find the vectors most likely to be leveraged by a cybercriminal.
- You decide the testing scope based on timing, risk, and business priorities.

The results will save your security operations teams valuable time by prioritizing the vulnerabilities that pose the most risk. You'll launch digital applications that are secure by design by feeding back findings to your developer teams. And, you'll be assured your security coverage is validated with standardized testing by specialized experts.

[Learn more about the HackerOne Attack Resistance Platform](#)

Company	Knowledge	Resources
Leadership	Center	Blog
Careers	Application Security	Documentation
Partners	Penetration Testing	Leaderboard
Newsroom	Cloud Security	Partner Portal
Contact Us	Hacking	Resources
	Cybersecurity	
	Attacks	

Contacted
by a [+](#)
hacker?

DevSecOps